Broken Access Control Leading to Unauthenticated File Overwrite

Palmr | CWE-639 reverse-share presigned URL accepts arbitrary object key

Vulnerability Name	Unauthenticated cross-user file overwrite via reverse-share presigned URL
Researcher	Kashish Topiwala
Severity	Critical
CVSS v3.1 Base Score	9.1
CVSS v3.1 Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H
CWE	CWE-639: Authorization Bypass Through User-Controlled Key
Affected Product	Palmr (kyantech/Palmr)
Affected Version	current (tested at commit 6d785dc)
Affected Component	POST /reverse-shares/:id/presigned-url and /reverse-shares/alias/:alias/presigned-url
Attacker Profile	Unauthenticated

Description

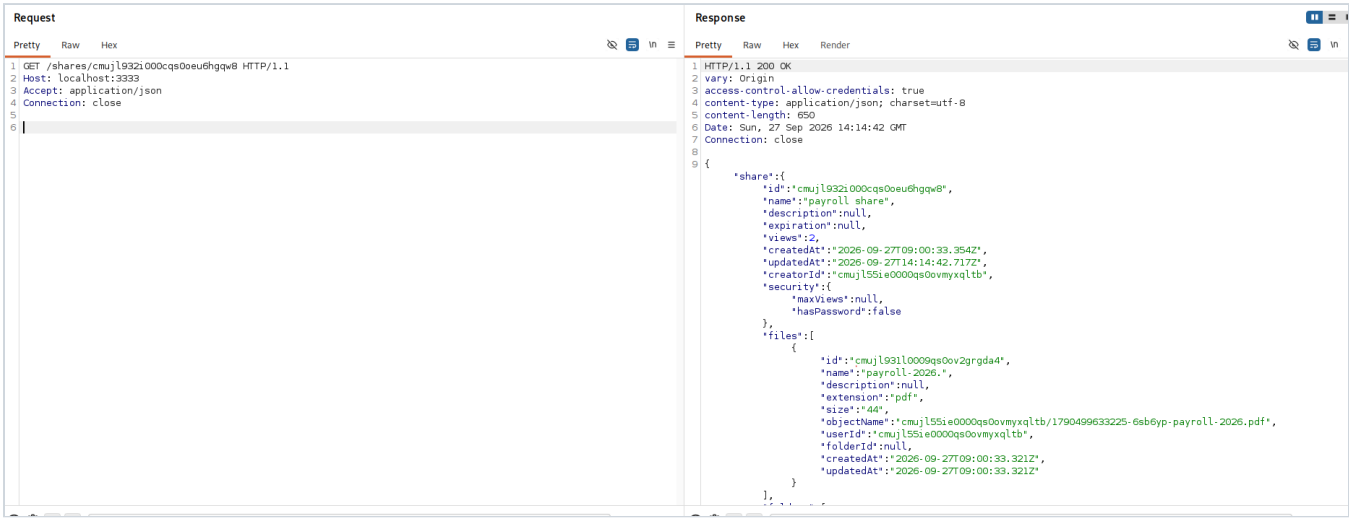
Anyone, without logging in, can ask Palmr for an upload link to any stored file and replace that file with their own content. When the victim or their recipients later download the shared file, they receive the attacker's content instead.

Affected Files

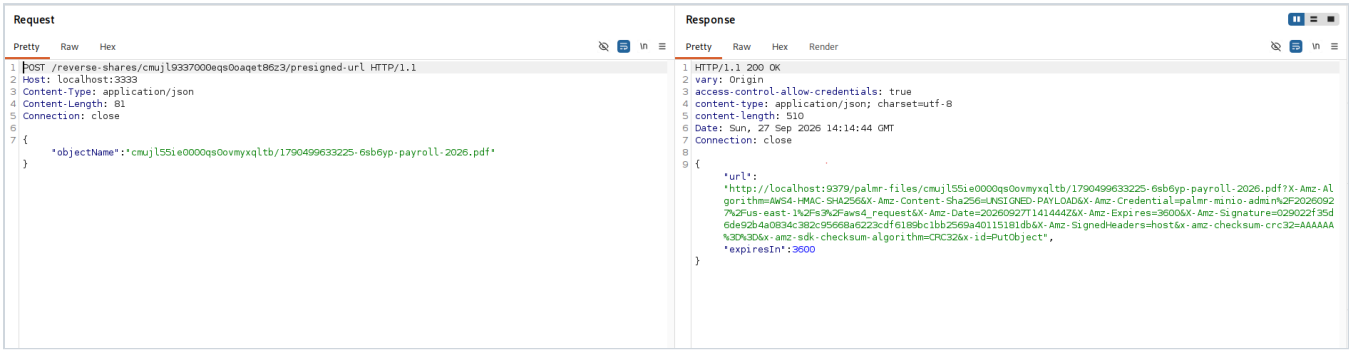
- Object key leaked to anyone: apps/server/src/modules/share/routes.ts (GET /shares/:id returns each file objectName)
- No auth + no key binding: reverse-share/routes.ts, controller.ts, service.ts (presigned-url handlers sign a PUT for the client-supplied objectName)

Steps to Reproduce

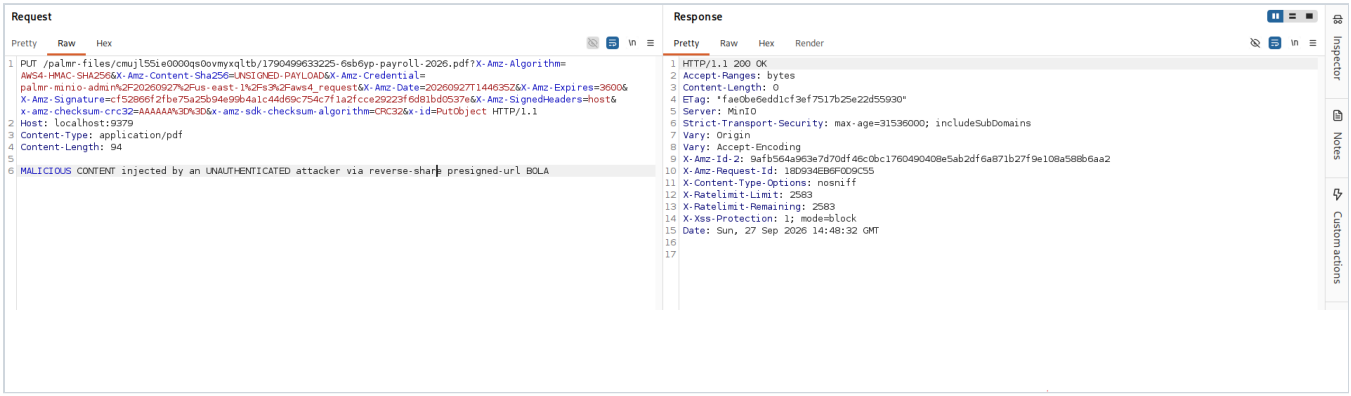
Step 1: Unauthenticated GET /shares/{id} against a victim public share. The response discloses the victim file's storage key (objectName).



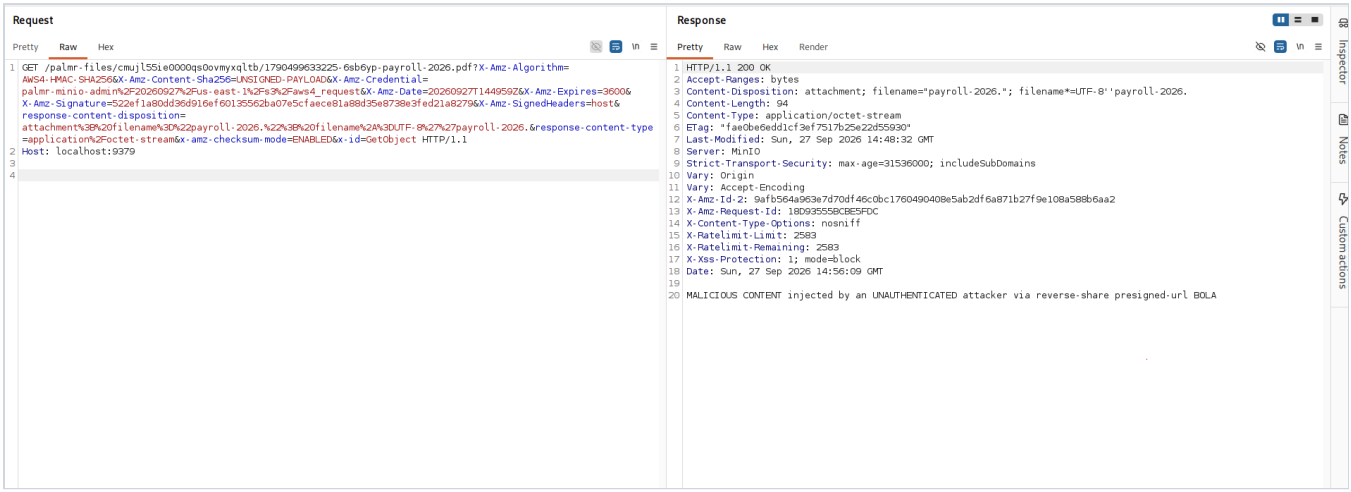
Step 2: Unauthenticated POST /reverse-shares/{id}/presigned-url with that objectName. The server returns a presigned PUT URL for the victim's key, with no authentication and no ownership check.



Step 3: Unauthenticated PUT of attacker bytes to the presigned URL. Storage returns HTTP 200; the victim's stored object is overwritten with attacker content.



Step 4: Downloading the victim's shared file now serves the attacker's content, confirming the cross-user overwrite.



Impact

- An unauthenticated attacker overwrites any file in the shared bucket, including other users' shared files, by supplying its object key.
- The object key is not secret: the public GET /shares/:id endpoint discloses it.
- Victims (and anyone they share with) then download attacker-controlled content in place of the original file (malware delivery, tampering).
- Integrity and availability of stored files are fully compromised with no credentials required.

Remediation

- Require authentication on the reverse-share presigned-upload endpoints and bind the presigned key to the reverse-share's own server-generated prefix; never accept a caller-supplied absolute objectName.
- Do not expose internal storage object keys in the public GET /shares/:id response.
- Scope every presigned URL to a single expected key derived server-side from the authorized context.

References

- https://cwe.mitre.org/data/definitions/639.html
- https://owasp.org/Top10/A01_2021-Broken_Access_Control/
- https://owasp.org/www-community/attacks/Path_Traversal